

공격 패턴 분석

1. 전체 공격 규모

2026년 7월 28일 18:46부터 7월 30일 15:43까지 확인된 핵심 공격 요청은 총 **698건**이다. 공격에 사용된 전화번호는 698개로 모두 서로 달랐으며, IP는 261개가 사용됐다.

전체 로그 기준 SMS 발송 성공 요청은 732건이지만, 정상 브라우저 요청을 제외하면 Firefox/153.0 계열 698건이 동일 공격 캠페인으로 판단된다. 차단된 Chrome/150 요청도 9건 확인됐다.

2. 공격 주기

요청 간격의 중앙값은 **90초**이며, 697개 연속 간격 중 462개가 60~120초 사이에 몰려 있다. 약 1~2분 사이의 랜덤 지연을 반복하는 자동화 봇의 전형적인 패턴이다.

동일 IP는 짧게 반복하지 않고 수 시간 간격으로 다시 사용했다. 전화번호와 IP를 지속적으로 교체해 번호별·IP별 레이트리미트를 회피하고 있다.

3. 시간대별 공격 패턴

- **7월 28일 18:46~22:58 KST**: Android Firefox/153.0 UA로 55건 발송
- **7월 29일 00:33~07:05 KST**: 차단된 Chrome/150 UA로 재시도, 9건이 **ua-blocked** 처리
- **7월 29일 15:28 KST 이후**: Windows Firefox/153.0 UA로 전환해 643건 발송

초기 모바일 UA로 공격한 뒤 UA 차단을 확인하고 Windows Firefox UA로 변경했다. 변경 이후 공격량이 크게 증가했으며, 야간과 새벽에도 일정한 속도로 지속됐다.

4. IP 분석 — KT 회선망 기반 레지덴셜 프록시 추정

공격에는 261개 IP가 사용됐지만 **/24** 서브넷은 29개에 불과하다. 주요 대역은 **222.112.x.x**, **125.133.x.x**, **14.36.x.x**, **211.196.x.x** 등 KT/KORNET 계열 국내 유선망에 집중돼 있다.

같은 서브넷 내부에서 여러 IP를 순환하며 IP당 요청 수를 낮게 유지했다. Android UA 시기에 사용한 IP 대부분이 Windows UA 시기에도 다시 등장하므로 동일 공격자가 같은 프록시 풀을 계속 사용한 것으로 판단된다.

KT 가입자망을 출구로 사용하는 회전형 레지덴셜 프록시 가능성이 높다. 다만 실제 가정용 단말, 감염된 단말 또는 상업용 프록시 서비스 중 어느 유형인지는 로그만으로 확정할 수 없

다.

5. User-Agent 분석

핵심 공격 요청 698건은 두 UA에 집중돼 있다.

- Android Firefox/153.0: 55건
- Windows Firefox/153.0: 643건

IP와 전화번호는 계속 변경되지만 UA 문자열은 장시간 동일하게 유지됐다. 이는 여러 일반 사용자의 접속이 아니라 하나의 자동화 프로그램이 UA만 단계적으로 교체하며 실행된 패턴이다.

Chrome/150 UA가 차단되자 Firefox/153.0으로 전환한 점에서 공격자가 서버의 차단 정책을 확인하고 대응한 정황도 확인된다.

6. Turnstile 우회 판단

공격 요청 대부분이 Turnstile 검증을 통과했으며, `timeout-or-duplicate` 오류는 거의 발생하지 않았다. 기존 토큰을 반복 재사용한 것이 아니라 요청마다 새로운 유효 토큰을 확보한 것으로 보인다.

브라우저 자동화, anti-detect 브라우저 또는 CAPTCHA 토큰 해결 서비스를 사용했을 가능성이 높다. Playwright, Selenium, Camoufox 등이 후보지만 현재 로그만으로 특정 도구를 확정할 수는 없다.

Turnstile 자체가 직접 해킹됐다기보다 실제 브라우저 엔진 또는 외부 토큰 발급 인프라를 이용해 정상 토큰을 지속적으로 발급받은 것으로 판단된다.

7. 공격자 구조 추정

공격자는 하나의 중앙 자동화 프로그램에서 다음 과정을 반복하는 것으로 추정된다.

1. KT 회선 기반 프록시 풀에서 IP 선택
2. 무작위 또는 확보된 010 전화번호 선택
3. 실제 브라우저 엔진으로 페이지 접속
4. Turnstile 신규 토큰 발급
5. SMS 발송 API 호출
6. 60~120초 대기
7. IP와 전화번호를 변경해 반복

공격자는 인증 완료가 목적이 아니므로 `verify-code` 를 호출하지 않는다. 목적은 다수의 서로 다른 번호로 SMS 발송 비용과 민원을 발생시키는 SMS 펌핑 공격이다.